

ISO 27001 Auditor Checklist

Annex A control mapping for the Azure Zero-Trust Starter Pack (Acmebot, Hub & Spoke, Firewall)

HOW TO USE THIS SHEET

Hand this to your auditor or compliance lead alongside the deployed Terraform state. Each row maps a deployed resource to the Annex A control it satisfies — check it off once you've confirmed the resource is live and configured as documented in the module README.

MODULE: AZURE ACMEBOT — ENTERPRISE VNET EDITION

Control	Annex A	Terraform Resource
☐ Private network isolation for cert issuance	A.8.22	azurerm_private_endpoint + VNet Integration
☐ Automatic DNS resolution, no manual records	A.8.20	azurerm_private_dns_zone
☐ Least-privilege identity for cert renewal	A.8.2	azurerm_user_assigned_identity + RBAC

MODULE: ENTERPRISE HUB & SPOKE — ZERO-TRUST EDITION

Control	Annex A	Terraform Resource
☐ Network segmentation, Hub/Spoke isolation	A.8.22	azurerm_virtual_network peering + NSG
☐ Default-deny baseline on all Spoke subnets	A.8.20	azurerm_network_security_rule priority 4096
☐ Centralized Private DNS (Blob, SQL, KV, ACR)	A.8.20	azurerm_private_dns_zone_virtual_network_link
☐ Policy-managed resources don't drift on apply	A.5.36	lifecycle { ignore_changes } (DINE bypass)

MODULE: AZURE FIREWALL — ENTERPRISE FORCED TUNNELING EDITION

Control	Annex A	Terraform Resource
☐ All egress traffic routed through inspection	A.8.22	azurerm_route default 0.0.0.0/0 → Firewall
☐ FQDN allow-list for outbound traffic	A.8.22	azurerm_firewall_policy_rule_collection_group
☐ Platform services (KMS, Azure AD) not silently dropped	A.5.30	azurerm_route KMS/AAD bypass
☐ Firewall rule changes tracked in version control	A.8.32	Terraform state + Git history (no manual Portal edits)

Auditor note: This checklist covers the technical network infrastructure controls these three modules implement. Full ISO 27001 certification requires organizational measures (risk assessment, ISMS documentation, incident response procedures) beyond what infrastructure code alone provides. This sheet is evidence for Annex A technical controls — not a substitute for a full Statement of Applicability.